Built for trust. Ready to prove it.

A practical route to strong EU safety, security and data-protection assurance for German notarial workflows.

01

Protect

Office data & identities

02

Control

AI & approved handoffs

03

Prove

Tests & operating evidence

Implementation roadmap · not a compliance certificate

LexFlow has useful pilot safeguards. Production assurance still requires legal scoping, additional controls, validated deployment and independent evidence. This report defines that work and the gates for acceptance.

30 October 2026 · Version 1.0 · Baseline repository 9ad0caa

Prepared for the project team, office leadership, security reviewers and privacy advisers. No application behavior or production configuration is changed by this document.

01 / DECISION BRIEF

A credible path to high assurance

The project can be developed toward demanding EU requirements. The current pilot is a foundation, not evidence that every obligation has been satisfied.

LexFlow supports intake, extraction, source review, approval and controlled export for a dedicated German notary office. Its strongest existing safeguards are human review gates, encrypted office data, frozen approval snapshots and verifiable handoff receipts. The intended product remains an assistant to accountable professionals.

What “highest” should mean for this project

Use a demanding, risk-based security target: applicable law, documented safeguards, independent challenge and sustained operating evidence. There is no single universal EU certificate that proves every software product meets the highest possible safety and security level.

Decision	Required outcome
Keep the purpose narrow	Propose case data with evidence; require professional review. Do not introduce autonomous legal conclusions or irreversible filing without a fresh assessment.
Harden before real data	Approve supplier and privacy arrangements; enforce strong identity controls; validate the actual hosting, monitoring, key custody and recovery environment.
Prove each handoff	Keep ProNotar32 unavailable until the vendor contract, adapter, authorization and durable import acceptance are demonstrated.
Make assurance repeatable	Maintain control owners, test reports, incident drills, access reviews and independent assessment. Reassess material product and supplier changes.

Reading guide

Pages 3–4: applicability and dates. **Pages 5–6:** current baseline and target architecture. **Pages 7–13:** privacy, security, AI safety, integration and operations. **Pages 14–16:** governance, delivery and release gates. **Pages 17–19:** evidence and official sources.

Status vocabulary: IMPLEMENTED PILOT means supported by reviewed code or recorded local verification. REQUIRED means proposed work or evidence for the selected assurance target. CONDITIONAL means applicability depends on legal classification. UNVERIFIED means the relevant environment or outcome has not been demonstrated. A legal adviser should confirm the applicability record before production use.

02 / REGULATORY SCOPE

Apply the right obligations

Record the legal entity, deployment model, intended use and responsibilities before selecting a conformity route.

Framework	LexFlow assessment and action
GDPR Directly relevant	Notarial files contain personal data. Map controller/processor roles, lawful purposes, security, rights and retention. Assess additional conditions for special-category and criminal-offence data. [R01–R04]
EU AI Act Use-dependent	Determine which components qualify as AI and whether the intended use falls into a regulated category. Administrative notarial intake is not automatically high-risk. Provider and deployer responsibilities require separate analysis. [R05–R08]
Cyber Resilience Act Product-dependent	Assess distributed/on-premises software and any qualifying remote processing against the product scope. Do not assume all SaaS is covered or exempt. Identify manufacturer, support period and conformity route. [R09–R11]
NIS2 Entity-dependent	Check sector, service, size, designation and national transposition. A notary office is not automatically covered. A cloud or managed-service operator may be; customers may also require supplier controls. [R12]
eIDAS Function-dependent	Assess if qualified signatures, seals or trust services are introduced. Existing HMAC receipts and audit checkpoints are technical integrity controls, not qualified electronic signatures. [R16]
German notarial duties National overlay	Review professional secrecy and outsourced access under BNotO §26a. Case-specific services may require participant consent. Data-protection and professional obligations both need to be satisfied. [R13]

Required deliverable: an applicability register signed by office leadership and the product owner, with legal review. For each framework, record the legal basis, responsible entity, scope decision, applicable dates, required evidence and the trigger for reassessment.

This is a working applicability assessment, not a legal determination. Country-specific implementation, professional rules and the actual service contract can change the result. Voluntary ISO assurance is addressed on page 14.

Sources: [R02] EDPB security · [R06] AI Act Article 6 · [R09] Commission CRA scope · [R12] Commission NIS2 · [R13] BNotO §26a

03 / LEGAL TIMELINE

Plan against the current dates

Research cut-off: 30 October 2026. In particular, do not rely on the original high-risk AI timetable without checking its amendments.

Date / status	Consequence for planning
Already applicable GDPR	Apply relevant data-protection requirements before processing real office data. Software maturity does not defer these obligations. [R01–R04]
2 February 2025 AI Act early duties	Initial prohibited practices and AI-literacy provisions began applying. The current amended Article 4 requires measures supporting AI literacy; it does not require guaranteeing a particular individual skill level. [R05, R07]
2 August 2026 AI Act general date	Most provisions apply, subject to exceptions. Check transparency rules against actual functions. Using a third-party model does not by itself make LexFlow a general-purpose model provider. [R05]
11 September 2026 CRA reporting	Manufacturer reporting duties for actively exploited vulnerabilities and severe product-security incidents have started, where the product and role are in scope. Check transitional rules for the relevant release. [R09, R11]
2 December 2027 Annex III high-risk AI	Current Commission guidance gives this application date for the relevant high-risk use cases following the AI Omnibus amendment. Determine classification before selecting the obligations. [R05]
11 December 2027 CRA main obligations	Prepare product security, support, documentation and the applicable conformity process for covered products. [R09, R10]
2 August 2028 Annex I high-risk AI	Extended date for relevant AI embedded in regulated products. This is not the default timetable for an administrative notarial assistant. [R05]

The Commission states that the AI Omnibus entered into force on 27 July 2026; its Service Desk reproduces the consolidated text at that date. National NIS2 obligations depend on the applicable implementing law. Recheck the legal register at every release and before any market launch. Official guidance is useful evidence; final legal interpretation requires the applicable legislation and facts.

Sources: [R05] Commission AI timetable · [R07] AI Act literacy · [R09] Commission CRA scope · [R11] CRA reporting · [R12] Commission NIS2

04 / CURRENT PROJECT BASELINE

Useful controls already exist

These findings describe repository 9ad0caa and the local pilot evidence. They do not establish production effectiveness.

Implemented pilot safeguard	Boundary or remaining work
Evidence and approval Source checks, conflict handling, scan acknowledgement, role gates and frozen approval snapshots.	Review quality still depends on trained staff. Heuristic confidence is not a measured probability of correctness. [E01, E03]
Office encryption Per-office encrypted private fields, documents, snapshots and audit metadata; wrapped office keys.	Application processes can decrypt. Master-key custody, lifecycle, host hardening and operator access need stronger operational assurance. [E02]
Controlled handoff Versioned mappings, byte-bound HMAC requests/receipts, idempotency and pending states after timeout.	Reference receiver evidence is synthetic. Real vendor import and ProNotar32 support are unverified; the ProNotar32 adapter is unavailable. [E04]
Tamper-evident audit Hash chain, signed checkpoint, mutation guards and separately exportable latest anchors.	No WORM service is provisioned. An attacker with application keys and database control exceeds ordinary chain protections. [E05]
Recovery and cleanup Encrypted offline backups, fresh-target restore checks and delivery-based source cleanup.	Writers must be drained for consistent backups. Complete retention, legal holds, monitoring and hosted recovery objectives need acceptance. [E06]
Production configuration guards Dedicated-office requirements, secret checks and a PostgreSQL/HTTPS deployment template.	Hosted TLS, Docker runtime, cloud isolation and operational monitoring were not validated by the local test record. [E07]

Priority gaps

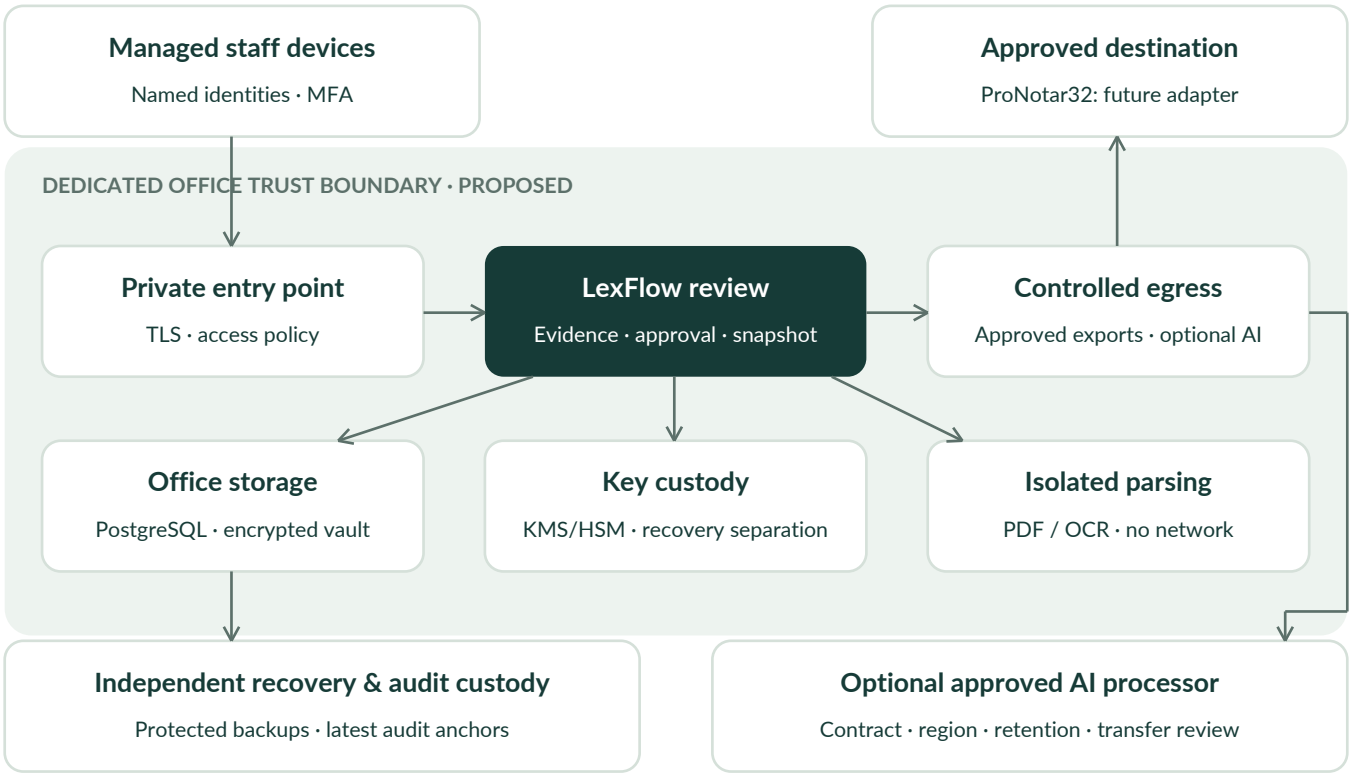
MFA/SSO and abuse controls; separate scoped integration credentials; isolated document processing; managed key custody; independent monitoring; supplier/privacy agreements; representative AI validation; external security testing. These are roadmap items, not claimed features.

The README records 152 passing tests on isolated PostgreSQL 17 on 30 October 2026. This report does not rerun that suite or independently certify its coverage. The documented 12-case synthetic evaluation is regression evidence, not representative office accuracy. Evidence references E01–E08 appear on page 17.

05 / TARGET ARCHITECTURE

Contain access and data movement

Proposed deployment boundary. This diagram includes controls that still need implementation and environment validation.



Keep each office isolated. Use separate application, database, vault, export storage, service credentials and keys. Validate isolation across requests, jobs, recovery tooling and operator sessions. The public marketing site remains outside the office environment, without case access.

Treat every document as hostile input. Move PDF/OCR parsing into restricted workers with CPU, memory, page and time limits; no ambient network or production secrets. Quarantine suspicious files and remove temporary plaintext after processing. Existing parser limits are a starting point, not full sandbox isolation.

Explicitly authorize egress. Permit only configured destinations. Keep external AI off until supplier, data categories, processing location and retention are approved. Documents must never choose endpoints, execute commands or change approval policy.

Threat model: stolen staff sessions; overprivileged integration tokens; malicious files; prompt injection; compromised administrators; wrong-party exports; dependency compromise; ransomware; backup theft and rollback of audit history. Review these threats with the actual operator before accepting the design.

Sources: [R02] EDPB security · [R10] CRA manufacturers

06 / DATA PROTECTION AND SECRECY

Make privacy operational

GDPR accountability needs records, decisions and working procedures alongside encryption.

1. Establish purposes and responsibilities

The notary will ordinarily control the purposes of office case processing; a hosted LexFlow operator may be a processor. Confirm the actual arrangement, including any separate operator purposes. Document lawful bases by workflow, extra conditions for sensitive data, recipients and notices. Do not default to consent as the basis for every notarial activity. Maintain processing records and assess DPO requirements. [R01]

2. Assess effects before using real files

Complete and record a DPIA screening. Given confidential documents and potentially sensitive personal information, the proposed assurance target is a full DPIA before the live pilot. Describe necessity, alternatives, misuse, inaccurate extraction, unauthorized access and mitigation. Seek required prior consultation if high residual risk cannot be reduced. [R01]

3. Control suppliers and international access

Agree processor terms, approved subprocessors, confidentiality, incident assistance, deletion/return, audit rights and exit arrangements. The preferred deployment profile keeps processing, backups and support within controlled EU/EEA arrangements. Hosting region alone does not resolve third-country access. Where transfers occur, establish a valid transfer mechanism and assess safeguards and foreign-access risk. EU-only hosting is a project choice, not a universal GDPR rule. [R03]

4. Respect notarial professional secrecy

BNotO §26a requires careful service-provider selection and contractual secrecy safeguards. Its paragraph 4 requires participant consent for access to secrets when a service directly serves an individual official matter. Have notarial counsel determine whether the proposed AI or support service falls within that provision. This is a separate question from the GDPR lawful basis. [R13]

Acceptance evidence

Approved data-flow inventory, processing records, DPIA and risk decisions; notices and supplier agreements; professional-secrecy assessment; transfer assessment where needed; a demonstrated access/correction/deletion request procedure with documented legal exceptions. The software must not silently promise erasure of legally retained records.

Sources: [R01] EDPB accountability · [R03] EDPB transfers · [R13] BNotO §26a

07 / TECHNICAL HARDENING

Protect identities, keys and hosts

Required controls for the proposed production assurance target. Implementation strength must match the documented risks.

Control / owner	Required outcome and acceptance check
Staff access Security + office	Introduce SSO and phishing-resistant MFA, named accounts, least privilege and timely offboarding. Validate login/reset rate limits, session expiry, privileged reauthentication and recovery without a bypass. Review access quarterly.
Integration identity Engineering	Replace the shared office token with individual client credentials: intake-only scope where possible, expiry, revocation and usage audit. Prove one client's revocation leaves others intact. Current tokens also permit case reads.
Key management Platform	Use managed KMS/HSM-backed custody where appropriate; separate data, signing and recovery roles. Test rotation, compromise recovery and access revocation. Existing Fernet encryption does not itself demonstrate a managed key lifecycle.
Host and network Platform	Validate TLS, private database/storage, controlled proxy trust, hardened containers, non-root execution, patching and restricted administrative paths. Test tenant isolation and deny-by-default outbound access.
Document processing Engineering	Add quarantine and malware controls, sandbox parsers and enforce resource limits. Verify malformed files cannot escape, exhaust the host or leak temporary data. Do not upload confidential files to public scanning services.
Detection and logs Operations	Alert on privileged changes, excessive downloads, credential abuse, failed receipt verification and audit anomalies. Keep logs free of document bodies, prompts, secrets and unnecessary personal data. Test routing and response.
Staff devices Office IT	Require supported systems, disk encryption, endpoint protection, screen locking and controlled export locations. Test remote access and scanner-agent permissions, including stolen-device recovery.

Acceptance should include independent penetration testing of the deployed system, followed by remediation and retesting. No unresolved critical findings or uncontrolled high risks should pass the release gate. Security tooling must itself be approved for confidential notarial information.

Sources: [R02] EDPB security · [R10] CRA manufacturers

08 / AI SAFETY AND HUMAN OVERSIGHT

Keep human judgment in control

The main safety risks are false confidence, missed conflicts, mixed identities and unreviewed downstream action.

Classify the intended use. Annex III includes certain systems assisting judicial authorities with interpreting facts/law or applying law. Administrative extraction for a notary is not automatically that use. If an Annex III category applies, a narrow preparatory-task exception requires a reasoned assessment; human review alone is not a blanket exemption. Profiling within the relevant Annex III context cannot use that exception. Document and register an Article 6(3) exemption where required. [R06, R08]

Hazard	Required safeguard and evaluation
Invented or misplaced facts	Retain source provenance and originals. Check that cited evidence supports the field and belongs to the correct person/property. An exact quote match alone does not establish semantic correctness.
Automation bias	Show missing values, competing evidence and unread pages. Require active review of critical fields and original scans. Allow correction, abstention and a fully manual route; never label heuristic scores as validated accuracy.
Prompt injection	Treat document content as data, including embedded instructions. Restrict model output to validated schemas. No model-controlled tools, destinations, policy changes or direct approval. Exercise adversarial documents.
Model or workflow drift	Version model/provider settings, prompts, normalizers and mappings. Re-evaluate before changes. Include German names, multiple parties, WEG, poor scans, dates, amounts, conflicting drafts and omitted pages.
Uncontrolled external use	Approve the provider contract, processing purposes, retention and location. Verify restrictions on training/reuse and support access. Use minimum necessary content and a local/manual fallback.

Required evidence: an intended-use statement, model/system inventory, hazard log and representative validation set with lawful provenance. Agree acceptance thresholds before testing; report missed critical errors, false matches, abstentions and reviewer corrections by workflow. A small synthetic corpus cannot support a general accuracy claim.

GDPR Article 22 also needs assessment if a future workflow makes solely automated decisions with legal or similarly significant effects. The proposed design requires meaningful human judgment and authority to reject the recommendation, rather than a nominal approval click. [R17]

Support staff AI literacy through training on limitations, source checking, escalation and incident reporting. Record training and practical exercises. If classified high-risk, add the applicable risk/quality management, documentation, conformity, monitoring and deployer duties, including a fundamental-rights assessment where required. [R07]

Sources: [R06] AI Act Article 6 · [R07] AI Act literacy · [R08] AI Act Annex III · [R17] GDPR automated decisions

09 / PRONOTAR32 AND EXTERNAL SYSTEMS

Make integration a controlled release

Current status: generic structured case export exists; a functioning ProNotar32 adapter and accepted vendor import do not.

The supplied screenshots identify useful business fields and workflows. They do not establish an API, import schema, supported automation method, licensing permission or successful import. Obtain current vendor documentation and an authorized test environment before implementation.

Gate	Required artifact or demonstrated behavior
1 · Contract	Agree the supported interface, schema/version, permitted automation, destination identity, account scope, error model and meaning of durable acceptance. Define responsibility for support and incidents.
2 · Mapping	Map lexflow.case/1 to vendor fields with versioned, reviewed profiles. Include repeated parties/properties, representative relationships, umlauts, missing fields, office file names and register references. Minimize fields sent.
3 · Authorization	Bind the exact office, target account and approved case. Require a new reviewed approval when material values or mappings change. Reauthenticate or obtain a second review for sensitive destination/configuration changes.
4 · Delivery	Test retries after timeout, duplicate requests, partial failure and crash after import. Reconcile the destination's stored data and identifiers. A transport success or checksum alone does not prove correct vendor application.
5 · Recovery	Define correction, cancellation and reconciliation with the vendor. Never assume an accepted legal record can be silently rolled back. Keep a controlled manual workflow when the interface is unavailable.
6 · Acceptance	Use sanitized fixtures followed by the office's authorized validation. Capture exact versions, expected/actual values, negative tests and signed acceptance. Enable the adapter only after all gates pass.

Preserve the existing integrity model

Keep immutable approval snapshots, exact-byte signing, idempotency and receipts. Protect approved export files after they leave LexFlow. Where qualified electronic signatures or seals are needed, integrate appropriate trust services separately; the existing HMAC scheme does not supply them.

Sources: [R16] eIDAS signature distinction

10 / SECURE PRODUCT LIFECYCLE

Build security into every release

A secure deployment depends on maintained software, a response process and trustworthy updates.

Before release

Maintain the threat model and security requirements alongside design decisions. Review security-sensitive changes independently. Run meaningful authorization, isolation, parser, approval and handoff tests. Add dependency, secret, container and static-analysis checks; keep the results with the release. Generate a machine-readable software bill of materials, pin dependencies and verify build provenance.

Deliver and maintain safely

Sign release artifacts and verify them before deployment. Document secure defaults, upgrades, backup compatibility, rollback constraints and supported versions. Create a vulnerability-reporting channel with a responsible response team, severity triage and coordinated disclosure. Set patch targets based on exposure and exploitability; emergency fixes must have a tested distribution path and customer communications.

If CRA applies	Evidence to prepare
Product scope and risk	Document the manufacturer role, intended use, component/remote-processing boundary and product classification. Determine the required conformity assessment rather than assuming self-assessment or third-party certification.
Technical documentation	Trace applicable essential requirements to design, test results and residual-risk decisions. Record the support period and user-facing security instructions.
Vulnerability handling	Maintain intake, triage, remediation, notification and lifecycle records. Connect actively exploited vulnerabilities and severe security incidents to the CRA reporting procedure.
Market obligations	Complete the applicable conformity route and declaration/CE requirements when required. Neither this report nor an ISO certificate establishes product conformity.

Release evidence should be reproducible

Each release should identify its source revision, dependencies, build artifacts, deployment configuration, tests, approvals, known limits and support status. Keep confidential test data out of public repositories and automated external services.

Sources: [R09] Commission CRA scope · [R10] CRA manufacturers · [R11] CRA reporting

11 / INCIDENT RESPONSE

Prepare for different reporting clocks

One event can trigger several regimes. Track awareness times, thresholds, recipients and follow-up obligations separately.

Regime / trigger	Notification path and timing
GDPR Personal-data breach	The processor informs the controller without undue delay. The controller notifies the supervisory authority without undue delay and, where feasible, within 72 hours of awareness, unless the breach is unlikely to risk individuals' rights/freedoms. Inform affected people without undue delay where high risk requires it. Record all breaches and decisions. [R04]
NIS2, if in scope Significant incident	Generally: early warning within 24 hours; incident notification within 72 hours; final report within one month of the incident notification. If ongoing, follow the progress/final-report rules. Confirm national recipients, significance criteria and special-sector exceptions. [R12]
CRA, if in scope Actively exploited vulnerability	Manufacturer: early warning within 24 hours of awareness; vulnerability notification within 72 hours. Final report within 14 days after a corrective or mitigating measure becomes available. Use the required reporting platform and recipients. [R11]
CRA, if in scope Severe product-security incident	Manufacturer: early warning within 24 hours; incident notification within 72 hours; final report within one month after the incident notification. Assess affected-user communications and required updates. [R11]

Operational response sequence

Detect and preserve: alert the incident lead, record awareness, secure relevant logs and preserve evidence without copying entire case files unnecessarily. **Contain:** revoke affected credentials, isolate workers, suspend risky exports and preserve a manual office workflow. **Assess:** involve the office, privacy/legal advisers and suppliers; classify each reporting threshold. **Recover:** restore trusted versions, reconcile receipts and confirm key integrity. **Learn:** assign corrective actions and retest.

Required before live use: named primary/deputy contacts, a maintained authority/CSIRT directory, preapproved report templates and a tabletop exercise covering ransomware, wrong-recipient export and compromised AI/API credentials. Contractual supplier notice targets must leave the controller enough time to act. Do not wait for a complete forensic report before a legally required initial notification.

Sources: [R04] EDPB breaches · [R11] CRA reporting · [R12] Commission NIS2

12 / RETENTION AND RESILIENCE

Recover safely. Delete deliberately.

Availability and lawful retention must be designed together, including the copies held outside the live database.

Data class	Required policy and implementation
Originals, email and OCR	Specify the purpose, retention trigger, authorized holds and deletion evidence. Existing cleanup begins after acknowledged delivery and removes source material; verify orphaned files, temporary files and retry failures.
Cases and approvals	Define schedules for structured values, review revisions, frozen snapshots, exports and receipts. The existing source purge does not erase these. Apply notarial record duties and rights-request exceptions before deletion.
Logs and analytics	Minimize personal content, limit readers and set a justified duration. Separate security evidence from operational debugging. Do not keep complete prompts or case text as default diagnostics.
Backups and suppliers	Define expiry, restoration restrictions and deletion/return on exit. A restore must not silently resurrect information due for deletion; replay approved deletion/hold decisions. Verify supplier copies and support attachments.

Current boundary: the configured pilot source-retention value is not a legal retention rule. The office must approve a schedule for each data class. Required legal holds need controlled authorization, scope, review and release; unrestricted storage is not an acceptable substitute.

Recovery target and proof

Agree maximum tolerable data loss (RPO) and recovery time (RTO) through an office impact assessment. An initial planning target could be **RPO ≤ 4 hours and RTO ≤ 8 hours**, subject to office approval and architecture changes. These are proposed engineering targets, not current measurements or legal minima.

Protect off-site backups and the recovery key under separate custody. Test fresh-target restoration and the compromise of the primary operator account. The current backup procedure requires draining all writers; meeting the target may require coordinated snapshots or a validated continuous-recovery design. Reconcile approved cases, vendor receipts and separately retained latest audit anchors after recovery.

Required evidence: timed restoration in the actual environment, documented writer consistency, integrity verification, independent anchor comparison, successful key recovery, deletion/hold reconciliation and a demonstrated manual continuity procedure. Repeat after major changes and on a risk-based schedule; quarterly drills are the proposed initial cadence.

Sources: [R01] EDPB accountability · [R02] EDPB security · [R13] BNotO §26a

13 / GOVERNANCE AND ASSURANCE

Give every control an owner

Strong assurance is a management practice supported by technical evidence and independent review.

Accountability	Responsibility
Office leadership / notary	Approve intended use, professional-secrecy decisions, staff roles, retention and residual operational risk. Accept the office-specific deployment and handoff.
Product owner	Control feature scope, legal classification triggers and public claims. Own the release evidence pack and supplier interface commitments.
Security + platform lead	Own threat modelling, hardening, keys, monitoring, vulnerability management, recovery and incident command. Maintain named deputies.
Privacy/legal advisers; DPO where required	Advise on lawful basis, DPIA, professional duties, processor/transfer terms and notifications. Preserve DPO independence; management remains accountable.
Engineering + AI quality owner	Implement preventive controls, regression and adversarial tests, representative evaluation, change control and safety monitoring.
Independent assessor	Challenge the deployment and evidence, test security boundaries and verify remediation. Keep the scope and limitations explicit.

Voluntary standards as an assurance framework

Use **ISO/IEC 27001:2022** to organize information-security risk management and the control system. Consider **ISO/IEC 42001:2023** for governance of AI development and use. Establish a defined scope, management reviews, internal audits and corrective actions; then consider independent certification when operating evidence is mature. [R14, R15]

Keep claims precise

An ISO management-system certificate has a defined organization and scope. It does not certify every product feature, satisfy every EU law or replace an applicable CE/conformity process. Do not claim “EU-certified,” “fully GDPR compliant,” “zero risk” or “ProNotar integrated” without specific, defensible evidence.

Proposed cadence: monthly risk and incident review; quarterly access, supplier and recovery review; independent assessment before launch and after material boundary changes. Recheck relevant harmonised standards and their actual legal scope before relying on a presumption of conformity.

Sources: [R14] ISO 27001 · [R15] ISO 42001

14 / DELIVERY ROADMAP

Sequence the work by release gates

Indicative phases from an approved start date. Duration depends on team capacity, vendor cooperation and assessment findings.

Phase / lead	Work and exit evidence
0–30 days Scope and ownership Product + office	Confirm legal entity, deployment and intended use. Complete applicability register, data flows, supplier inventory, threat model and DPIA screening. Assign owners, classify data and approve the release gates. Start the vendor interface discussion.
31–60 days Preventive controls Engineering + platform	Implement MFA/SSO, scoped client credentials, parser isolation, controlled egress, key custody and sensitive-log filtering. Test authorization and data isolation. Complete privacy, confidentiality and supplier arrangements.
61–90 days Operational proof Operations + AI quality	Validate the actual deployment, backup/recovery and deletion policies. Exercise notifications and manual continuity. Evaluate representative authorized documents; tune review controls. Establish SBOM, release provenance and vulnerability response.
91–120+ days Independent challenge Assessor + office	Run external testing, remediate and retest. Review the evidence pack and residual risks. Accept only the demonstrated office/workflow scope. Start a tightly supervised live pilot only after all blocking gates pass.
Separate vendor gate Integration lead	Develop ProNotar32 only against an agreed interface and authorized fixtures. Validate mapping, duplicate handling, durable import and recovery. Its delivery date depends on vendor evidence, not this indicative schedule.
Ongoing Management	Maintain monitoring, access reviews, supplier assurance, reassessment and drills. Progress any applicable CRA/AI conformity work and optional ISO certification against actual legal deadlines.

Do not wait for a future milestone to meet an active duty

Where CRA reporting or other obligations already apply to an in-scope marketed product or operating service, the relevant process is needed now. The phased engineering plan does not defer statutory requirements.

This is a sequencing proposal, not a fixed-price estimate or a promise of certification within 120 days. Budget explicitly for legal/privacy review, managed identity and key services, monitoring, independent testing, representative evaluation and office training.

Sources: [R05] Commission AI timetable · [R11] CRA reporting

15 / PRODUCTION ACCEPTANCE

Release only against evidence

Proposed acceptance checklist. Every row requires an accountable sign-off for the actual release and office environment.

Gate	Evidence required before acceptance
G1 · Legal and privacy	Approved applicability decision, processing records, DPIA/consultation outcome as required, professional-secrecy assessment, retention, notices and signed supplier terms. No unresolved legal blocker.
G2 · Access and isolation	MFA and account-recovery tests; individual client revocation; least-privilege and tenant-boundary tests; verified admin controls. No cross-office disclosure or shared demo credentials in production.
G3 · AI and review	Documented intended use, representative evaluation and pre-agreed thresholds; successful conflict, scan and wrong-party checks; adversarial-document tests; trained reviewers and a manual fallback.
G4 · Deployment security	Verified TLS, secret/key custody, restricted network paths, sandbox behavior, privacy-safe logs and alert response. Independent testing completed; critical findings closed and uncontrolled high risks resolved.
G5 · Recovery and lifecycle	Timed restore within agreed objectives, trusted audit anchors, tested holds/deletion and exit procedures. Incident exercise completed. Supported release, SBOM, patch ownership and reporting readiness recorded.
G6 · Destination integrity	Approved mapping/version and endpoint identity; persisted destination values verified; retry/replay/timeout tests; durable receipt semantics and correction process. Keep unaccepted adapters disabled.
G7 · Accountable operation	Named office and operator owners, escalation contacts, operating runbooks and accepted residual risks. Complete any legally required conformity or registration steps before the relevant release/use.

Acceptance record: identify the exact application revision, model/provider configuration, mapping revision, host environment, office, test date and permitted workflows. Attach the supporting artifacts and any narrowly scoped conditions. The approving office and product/operator leads should sign the record.

Stop or restrict operation if isolation fails, a critical approval gate can be bypassed, important alerts go unhandled, recovery cannot be demonstrated or a vendor import changes meaning unexpectedly. Scope expansion, a new AI provider, new external data access or a material security change reopens the relevant gates.

16 / EVIDENCE AND METHOD

What this report is based on

A review of project artifacts and official public guidance. No production audit, vendor acceptance or certification was performed.

ID / evidence	Repository reference
E01 · Baseline and recorded tests	README.md; presentation/VERIFICATION.txt; apps/core/tests/. The README records 152 passing PostgreSQL tests. Those results were not rerun for this document.
E02 · Encryption and identities	apps/core/crypto.py; apps/core/models.py; config/settings.py. Office key wrapping, field encryption, shared-token limits and production settings.
E03 · Review and case integrity	apps/matters/services.py; apps/matters/case_data.py; apps/matters/engine/; apps/studio/validation.py. Review, evidence and snapshot boundaries.
E04 · Connectors	apps/connectors/adapters.py; apps/connectors/protocol.py; integrations/HANDOFF_V1.txt; integrations/PRONOTAR32_READINESS.txt. Implemented protocol and explicit vendor boundary.
E05 · Audit	apps/audit/models.py; apps/audit/checkpoints.py; apps/audit/services.py. Chain/checkpoint design and independent-anchor requirement.
E06 · Recovery and retention	deployment/OPERATIONS.txt; apps/core/management/commands/lexflow_backup.py; lexflow_restore.py in the same directory; apps/intake/management/commands/lexflow_purge.py.
E07 · Hosting	deployment/compose.yaml; deployment/Caddyfile; config/settings.py; lexflow_pilot_check command. Templates and guardrails do not prove hosted enforcement.
E08 · Evaluation limits	evaluation/property_cases.json; tools/verify_pilot_acceptance.py; apps/core/evaluation.py. Synthetic regression evidence needs representative office validation.

Baseline: repository commit 9ad0caa. Negative findings mean a control or its assurance was not established in the reviewed artifacts; an external operator may provide additional evidence. This assessment contains no real case records, credentials or private client details.

Official sources were checked on 30 October 2026. The Commission's current AI timetable and Service Desk consolidated articles were used for the 2026 amendments. Some direct EUR-Lex pages returned automated-access challenges; this report does not claim a complete independent review of every consolidated legal text. Legal advisers should verify the definitive texts and national implementation before signing the applicability record.

Reproduction: edit presentation/security-roadmap.json, then run .venv/bin/python tools/build_security_report.py. The build writes the PDF and a searchable plain-text companion. Review legal dates and project claims before issuing a new version.

17 / OFFICIAL SOURCES · 1 OF 2

Data protection and AI

Clickable primary-source references. Research date: 30 October 2026.

[R01] European Data Protection Board — Be compliant

Privacy by design/default, processing records and DPIA. GDPR Regulation (EU) 2016/679 is the underlying law; assess the relevant Articles 5–6, 9–10, 12–22, 24–25, 28, 30 and 35–37.

https://www.edpb.europa.eu/sme/be-compliant/be-compliant_en

[R02] European Data Protection Board — Secure personal data

Risk-appropriate technical and organizational safeguards under GDPR, including confidentiality, integrity and availability. Supports the security objectives, not a finding that LexFlow has achieved them.

https://www.edpb.europa.eu/sme/be-compliant/secure-personal-data_en

[R03] European Data Protection Board — International data transfers

Chapter V transfer mechanisms and their relationship to the other GDPR requirements. A hosting-region label alone is not a transfer assessment.

https://www.edpb.europa.eu/sme/be-compliant/international-data-transfers_en

[R04] European Data Protection Board — Data breaches

Breach assessment, records, supervisory-authority notification and communication to affected people; GDPR Articles 33–34.

https://www.edpb.europa.eu/sme/assess-the-risks/data-breaches_en

[R05] European Commission — AI Act

Current policy overview and application timeline, including the AI Omnibus that the Commission states entered into force on 27 July 2026. Underlying AI Act: Regulation (EU) 2024/1689, as amended.

https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai

[R06] Commission AI Act Service Desk — Article 6

High-risk classification and the documented Article 6(3) exception; read the displayed statutory text, not only the non-binding summary. Consolidated basis stated as 27 July 2026.

https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-6

[R07] Commission AI Act Service Desk — Article 4

Amended AI-literacy support measures for providers and deployers; the text distinguishes supporting development from guaranteeing an individual's skill level.

https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-4

[R08] Commission AI Act Service Desk — Annex III

Listed high-risk uses, including point 8 on administration of justice and democratic processes. Intended use and the relevant conditions drive classification.

https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3

18 / OFFICIAL SOURCES · 2 OF 2

Cybersecurity and assurance

Read each framework within its actual product, entity and deployment scope.

[R09] European Commission — Cyber Resilience Act

Regulation (EU) 2024/2847: product-security framework and staged application dates. Scope and transitional treatment require product-specific review.

https://digital-strategy.ec.europa.eu/en/policies/cyber-resilience-act

[R10] European Commission — CRA: Manufacturers

Risk assessment, technical documentation, conformity, CE/declaration, stated support period and vulnerability handling for manufacturers within scope.

https://digital-strategy.ec.europa.eu/en/policies/cra-manufacturers

[R11] European Commission — CRA reporting obligations

Reporting from 11 September 2026, distinct vulnerability and severe-incident stages, follow-up deadlines and the Single Reporting Platform.

https://digital-strategy.ec.europa.eu/en/policies/cra-reporting

[R12] European Commission — NIS2 Directive: FAQs

Directive (EU) 2022/2555: entity scope, risk management and staged incident reporting. Confirm the applicable Member State's implementation and competent authorities.

https://digital-strategy.ec.europa.eu/en/faqs/directive-measures-high-common-level-cybersecurity-across-union-nis2-directive-faqs

[R13] German federal legislation portal — BNotO §26a

Professional duties for notaries using service providers, including secrecy contracts and paragraph 4's case-specific participant-consent requirement. This is national law, not an EU regulation.

https://www.gesetze-im-internet.de/bnoto/__26a.html

[R14] ISO — ISO/IEC 27001:2022

Official overview of the information security management system standard. Voluntary organizational assurance; not a universal product or EU compliance certificate.

https://www.iso.org/standard/27001

[R15] ISO — ISO/IEC 42001:2023

Official overview of the AI management system standard. The full paid standards were not independently audited against the project for this report.

https://www.iso.org/standard/42001

[R16] Court of Justice — Case C-466/22, judgment of 29 February 2024

Primary judicial source discussing eIDAS Article 25 and qualified signatures. HMAC evidence must not be represented as a qualified signature or as satisfying notarial form requirements.

https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=ecli:ECLI:EU:C:2024:185

[R17] European Commission — Information for individuals

GDPR rights and automated decision-making, including Article 22. Relevant to any future expansion beyond staff-reviewed extraction.

https://commission.europa.eu/law/law-topic/data-protection/information-individuals_en